

3 - Security Objectives

🕒 Created	June 24, 2026 12:20 AM
🏷️ Tags	

STRIDE (threat)	Thuộc tính cần bảo vệ	Mục tiêu	Threats
S - Spoofing	Authenticity	Mọi request truy cập tài nguyên được bảo vệ phải mang một danh tính được xác thực bằng bằng chứng mật mã mà gateway kiểm độc lập được, request không/bằng chứng sai phải bị từ chối	S1-IG, S1-GB. S1-IdP
T - Tampering	Integrity	Nội dung mỗi request (body + tham số quan trọng) PHẢI được bảo toàn nguyên vẹn từ lúc gửi tới lúc xử lý và không thể replay: mỗi request chỉ có hiệu lực một lần trong một cửa sổ thời gian giới hạn	T1-IG, RP1-IG
R - Repudiation	Non-repudiation	Mọi hành động quan trọng (đặc biệt giao dịch M2M) PHẢI gắn được với chủ thể thực hiện bằng bằng chứng mà chỉ chủ thể đó tạo ra được; bằng chứng + dấu vết PHẢI được lưu bất khả sửa/xóa	R1-IG
I - Information disclosure	Confidentiality	Mọi thông tin bí mật/được bảo vệ (khóa, secret) PHẢI được mã hóa khi lưu trữ và khi truyền; chỉ chủ	I1-IG, I1-Vault

STRIDE (threat)	Thuộc tính cần bảo vệ	Mục tiêu	Threats
		thể được cấp quyền mới đọc được.	
D - Denial of Service	Availability	Hệ thống PHẢI duy trì khả năng phục vụ người dùng hợp lệ ngay cả khi có lưu lượng bất thường/lạm dụng; không một nguồn đơn lẻ nào được làm cạn kiệt tài nguyên xử lý	D1-IG
E - Elevation of privilege	Authorization	Mỗi truy cập tới một chức năng/tài nguyên PHẢI được kiểm quyền - chủ thể chỉ thực hiện được đúng phần danh tính nó được cấp; quyền phải được kiểm lại ở mỗi tầng (gateway và backend), không uỷ thác mù; vượt quyền → 403	E1-IG, E2-GB